МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РФ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО ОБРАЗОВАНИЯ
«ВОРОНЕЖСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»
(ФГБОУ ВО «ВГТУ», ВГТУ)
Факультет информационных технологий и компьютерной безопасности
Кафедра систем информационной безопасности

ОТЧЁТ
по научно-исследовательской работе студента

Тема: «Разработка интеллектуальной системы оценки и регулирования киберрисков корпоративной DevOps-инфраструктуры при нарушении безопасности CI/CD-процессов »

Разработал студент
гр. ИБ-211 «_____» С.И. Ширинкин
Подпись, дата Инициалы, фамилия

Руководитель:_____«_____»_____
Подпись, дата, должность, инициалы, фамилия

Защищен _____ Оценка _____
дата

Воронеж 2026

СОДЕРЖАНИЕ

ВВЕДЕНИЕ 3

1 Модель угроз корпоративной DevOps-инфраструктуры на основе базы недостатков безопасности CI/CD-процессов 11

1.1 Корпоративная DevOps-инфраструктура как объект защиты: этапы конвейера, активы, модель эксплуатации 11

1.2 Недостатки безопасности CI/CD-процессов как источник риска и их отличие от уязвимостей программного кода 14

1.3 Нормативно-правовое обеспечение защиты DevOps-инфраструктуры и требования к безопасности конвейера 17

1.4 Информационные источники сведений о недостатках безопасности CI/CD и их сопоставление с техниками MITRE ATT&CK 19

1.5 Формирование базы соответствий «недостаток безопасности этапа конвейера — эксплуатирующая техника — наступающий ущерб» 21

1.6 Классификация недостатков безопасности CI/CD и построение дерева угроз и индуцированных ими рисков 23

1.7 Выводы по первой главе 28

СПИСОК ЛИТЕРАТУРЫ 29

ПРИЛОЖЕНИЕ А 33

ПРИЛОЖЕНИЕ Б 34

ВВЕДЕНИЕ

Современная разработка программного обеспечения перешла к модели непрерывной интеграции и непрерывной поставки (Continuous Integration / Continuous Delivery, CI/CD): исходный код, сторонние зависимости, автоматизированная сборка, хранение артефактов и развёртывание в промышленную среду образуют единый автоматизированный конвейер. В корпоративной DevOps-инфраструктуре такой конвейер обладает высоким уровнем доверия и широкими полномочиями вплоть до прямого доступа в промышленную среду, что делает его самостоятельным объектом кибератак.

Актуальность темы обусловлена устойчивым смещением вектора атак с готового программного продукта на процесс его сборки и поставки. По данным ежегодного отчёта Sonatype «State of the Software Supply Chain», только за 2023 год в открытых репозиториях пакетов выявлено более 245 тысяч вредоносных программных компонентов — больше, чем суммарно за все предшествующие годы наблюдений [1]. Крупные инциденты компрометации цепочки поставки — атака на SolarWinds (2020) [2], компрометация Codecov (2021) и внедрение бэкдора в библиотеку сжатия XZ Utils (уязвимость CVE-2024-3094, 2024) [3] — показали, что нарушение безопасности конвейера ведёт к массовой компрометации потребителей продукта и по величине ущерба сопоставимо с компрометацией самой промышленной системы.

Отраслевая статистика подтверждает тенденцию в динамике. Согласно отчёту Verizon «Data Breach Investigations Report» за 2024 год, доля нарушений, реализованных через цепочку поставки и сторонние компоненты, выросла и составила около 15 %, что вдвое превышает показатель предыдущего периода [4]. По данным компании GitGuardian, число утёкших в публичные репозитории GitHub секретов увеличилось с 10 миллионов в 2022 году до 12,8 миллиона в 2023 году и продолжило рост в 2024 году [5]. Отечественные исследования фиксируют аналогичную картину: по оценке экспертов Positive Technologies, доля целевых атак на российские организации, использующих компрометацию подрядчиков и сторонних сервисов, в 2024–2025 годах устойчиво возрастает [6].

Экономические последствия компрометации конвейера сопоставимы с последствиями компрометации самой промышленной системы. По оценке отчёта IBM «Cost of a Data Breach Report» за 2024 год, средняя стоимость утечки данных для организации превысила 4,8 млн долларов, а инциденты, связанные с компрометацией цепочки поставки и сторонних компонентов, относятся к числу наиболее продолжительных по времени выявления и локализации [7]. Это подчёркивает, что защищённость процесса сборки и поставки является не вспомогательной, а критической характеристикой корпоративной информационной системы.

Таким образом, обеспечение защищённости корпоративной DevOps-инфраструктуры требует не разрозненного контроля отдельных недостатков конфигурации конвейера, а системной оценки и регулирования индуцируемых ими киберрисков, что определяет актуальность настоящего исследования.

Актуальность усиливается регуляторным контекстом Российской Федерации. Требования ФСТЭК России к защите информации в государственных информационных системах и к безопасности значимых объектов критической информационной инфраструктуры распространяются в том числе на среду разработки и сопровождения программного обеспечения, а курс на технологическую независимость повышает значимость контроля собственной цепочки поставки и доверия к используемым компонентам. В этих условиях оценка киберрисков процессов сборки и поставки становится не только технической, но и нормативно обусловленной задачей.

Степень проработанности темы. Вопросы безопасности процессов разработки отражены в отраслевых источниках знаний — перечне OWASP Top 10 CI/CD Security Risks [8], практиках безопасной разработки NIST SP 800-218 [9], спецификации уровней зрелости цепочки поставки SLSA [10] и релевантных техниках матрицы MITRE ATT&CK [11]. Разработаны и средства анализа — Checkov, Snyk, GitGuardian, Trivy и другие. Вместе с тем перечисленные источники и средства дают преимущественно дискретную оценку соответствия требованиям и обнаружение отдельных недостатков, но не переводят их в меру риска, не учитывают связность конвейера и не обеспечивают переоценку состояния при

изменении конфигурации. Эти нерешённые вопросы образуют пространство противоречий, разрешаемых в настоящей работе.

Отдельное направление составляют работы по сценарному моделированию кибератак на основе матрицы MITRE ATT&CK и оценке рисков цепочки поставки программного обеспечения. Однако в существующих исследованиях объектом защиты выступает преимущественно абстрактная автоматизированная информационная система, тогда как процесс её сборки и поставки как самостоятельный объект риск-анализа остаётся проработанным недостаточно: отсутствуют модель угроз конвейера, привязанная к его этапам, и методика количественной оценки недостатков, не обладающих идентификаторами уязвимостей. Восполнение этого пробела и составляет содержание настоящей работы.

Объектом исследования является корпоративная DevOps-инфраструктура, реализующая процессы непрерывной интеграции и поставки программного обеспечения (CI/CD-конвейер), подверженная кибератакам, эксплуатирующим нарушения безопасности этих процессов.

Предметом исследования являются процессы оценки и регулирования киберрисков успешности реализации нарушений безопасности CI/CD-процессов, включающие установление соответствия между недостатками безопасности этапов конвейера и техниками их эксплуатации, количественную оценку меры риска и выработку мер её снижения.

Целью исследования является повышение защищённости корпоративной DevOps-инфраструктуры от кибератак, эксплуатирующих нарушения безопасности CI/CD-процессов, за счёт создания интеллектуальной системы оценки и регулирования киберрисков.

В работе используется терминология, закреплённая в научно-методических рекомендациях кафедры [12]: безопасность — состояние защищённости от внешних и внутренних угроз, при котором риск реализации этих угроз не превышает допустимых значений; угроза — совокупность факторов, воздействие которых способно привести к ущербу; риск — возможность наступления ущерба от реализации угроз; ущерб — совокупность негативных последствий реализации

угроз; мера риска — произведение величины ожидаемого ущерба на вероятность его наступления.

Исследование аналогов и действующих источников знаний о нарушениях безопасности CI/CD-процессов позволяет констатировать наличие следующих противоречий между:

1) объективной потребностью оценивать защищённость самого процесса сборки и поставки программного обеспечения и тем, что действующие реестры уязвимостей — NVD и банк данных угроз ФСТЭК России — описывают дефекты готовых программных продуктов, тогда как нарушение безопасности конвейера порождается его организацией — правами исполнителя сборки, порядком подключения зависимостей и условиями запуска заданий;

2) практикой предоставления конвейеру постоянных привилегированных учётных данных для доступа к репозиториям, реестрам и средам развёртывания и отсутствием методического обеспечения, позволяющего оценить ущерб от компрометации конкретного секрета конвейера, вследствие чего обнаружение секрета средствами класса GitGuardian фиксируется как событие, но не переводится в меру риска;

3) требованиями к подтверждению происхождения и целостности собираемых артефактов, закреплёнными в уровнях зрелости SLSA, и фактической возможностью подмены артефакта между сборкой и развёртыванием, не выявляемой средствами анализа исходного кода и состава зависимостей, работающими до этапа сборки;

4) потребностью в количественной оценке критичности нарушений безопасности CI/CD-процессов и возможностями применяемых калькуляторов критичности — CVSS 4.0 и EPSS, — принимающих на вход уязвимость с присвоенным идентификатором, тогда как избыточные права исполнителя сборки или отсутствие проверки подписи артефакта таким идентификатором не обладают;

5) связным характером конвейера, в котором компрометация одного звена наследуется всеми последующими этапами вплоть до промышленной среды, и событийным характером срабатываний средств Checkov, Snyk и GitGuardian, фиксирующих отдельный факт без оценки его распространения по цепочке доверия;

6) сложившейся практикой регламентации мер защиты в отношении разрабатываемого программного продукта и объективной необходимостью регламентации противодействия нарушениям безопасности самого процесса его сборки и поставки, включая порядок действий при компрометации зависимости, секрета и артефакта.

Для разрешения перечисленных противоречий и достижения поставленной цели необходимо решить следующие задачи:

1) организация сбора и суммаризации сведений о недостатках безопасности CI/CD-процессов по этапам конвейера на основе OWASP Top 10 CI/CD Security Risks, NIST SP 800-218 и матрицы MITRE ATT&CK с формированием структурированной базы «этап конвейера — недостаток — техника эксплуатации — ущерб»;

2) проведение инвентаризации секретов конвейера и разработка методики оценки ущерба от их компрометации с учётом области действия учётных данных, срока их жизни и достижимых с их помощью сред развёртывания;

3) разработка методики оценки доверия к артефакту сборки, учитывающей подтверждение происхождения, воспроизводимость сборки и полноту проверки подписи на этапе развёртывания;

4) разработка методики количественной оценки критичности нарушений безопасности CI/CD-процессов на основе адаптации метрик CVSS 4.0 с учётом уровня зрелости цепочки поставки и объёма полномочий исполнителя сборки;

5) разработка программного обеспечения, реализующего оценку уровня риска конвейера обученной моделью и расчёт распространения компрометации по этапам цепочки доверия с построением риск-ландшафта DevOps-инфраструктуры;

6) формирование частных регламентов выявления, реагирования и ликвидации последствий нарушений безопасности CI/CD-процессов и комплекса мер противодействия, ранжированных по масштабности и профильности.

Методами исследования служат теория рисков и вероятностное моделирование; теория графов (представление сценариев эксплуатации и распространения компрометации как путей в графе цепочки доверия); методы машинного обучения на табличных данных для восстановления оценки критичности

и классификации конвейеров по уровню риска; методики ФСТЭК России по оценке угроз безопасности информации [13]; методы экспертных оценок.

На защиту выносятся следующие результаты исследования:

1) база знаний недостатков безопасности CI/CD-процессов, структурированная по этапам цепочки доверия: репозиторий, система сборки, хранилище артефактов, среда развёртывания;

2) методика оценки ущерба от компрометации секретов конвейера и реестр секретов, ранжированный по области действия и достижимым средам;

3) методика оценки доверия к артефакту и шкала соответствия полученных оценок уровням зрелости цепочки поставки;

4) расчётная методика и реализующий её алгоритм, определяющие меру риска нарушения безопасности конвейера как ожидаемый ущерб, взвешенный вероятностью его наступления;

5) программное обеспечение интеллектуальной системы с моделью классификации конвейеров по уровню риска, обученной на размеченном множестве реальных конфигураций, и риск-ландшафт конвейера в измерениях «этап — техника — мера риска»;

6) комплекс политик и частных регламентов противодействия нарушениям безопасности конвейера и количественная оценка снижения его риск-ландшафта после внедрения предложенных мер.

Научная новизна результатов состоит в том, что:

1) недостатки безопасности впервые отнесены не к средствам автоматизации сборки как к программным продуктам, а к этапам конвейера как к звеньям цепочки доверия, обладающим собственным набором полномочий;

2) секрет конвейера впервые рассматривается как самостоятельный объект риск-анализа, характеризуемый областью действия и достижимыми средами, а не как единичный факт обнаружения;

3) осуществлён переход от качественной констатации уровня зрелости цепочки поставки к количественной оценке доверия к конкретному артефакту на конкретном этапе его движения по конвейеру;

4) вектор оценки критичности впервые дополнен характеристиками процесса сборки — объёмом полномочий исполнителя и достижимостью промышленной среды, которые в исходных калькуляторах не предусмотрены;

5) риск конвейера впервые вычисляется как результат распространения компрометации по цепочке доверия с наследованием привилегий последующими этапами, а оценка уровня риска конфигурации конвейера получена обучением на множестве реальных конфигураций, а не экспертным путём;

6) предложенные регламенты привязаны к узлам дерева угроз конвейера и сопровождаются расчётом достигаемого снижения меры риска, что отличает их от рекомендательных требований действующих стандартов.

Практическая ценность результатов заключается в том, что каждый из них:

1) применим при проектировании защиты DevOps-инфраструктуры как перечень контролируемых точек конвейера с указанием техники эксплуатации и ожидаемого ущерба;

2) применим для обоснования перехода к краткоживущим учётным данным и для приоритизации ротации секретов по величине предотвращаемого ущерба;

3) применим для выявления этапов конвейера, на которых подмена артефакта остаётся невыявляемой, и для обоснования внедрения подписи артефактов;

4) применим для ранжирования этапов конвейера по критичности и для сравнения защищённости нескольких конвейеров организации между собой;

5) применим для выявления этапов, нарушение которых влечёт наибольший ущерб для промышленной среды, и для непрерывной переоценки риска при изменении конвейера;

6) применим как основа частных инструкций персоналу, сопровождающему процессы непрерывной интеграции и поставки в корпоративной среде.

Теоретическая ценность результатов состоит в том, что каждый из них:

1) развивает теорию оценки рисков цепочки поставки программного обеспечения в части описания процесса разработки как объекта защиты и допускает распространение на процессы GitOps и доставки моделей машинного обучения;

2) развивает теорию управления доверием в автоматизированных процессах в части количественного описания последствий компрометации машинных учётных данных;

3) развивает теорию доверенной среды разработки в части формализации свойства происхождения артефакта и допускает перенос на межорганизационные цепочки поставки;

4) развивает теорию риск-калькуляции в части оценки объектов, не обладающих идентификаторами уязвимостей и статистикой эксплуатации;

5) развивает теорию распространения рисков в связных технологических процессах и создаёт основу для оценки рисков цепочки поставки за пределами одной организации;

6) развивает методологию управления рисками цепочки поставки в части перехода от рекомендаций к измеримым мерам регулирования.

1 Модель угроз корпоративной DevOps-инфраструктуры на основе базы недостатков безопасности CI/CD-процессов

1.1 Корпоративная DevOps-инфраструктура как объект защиты: этапы конвейера, активы, модель эксплуатации

Методология DevOps и практика непрерывной интеграции и непрерывной поставки (CI/CD) стали отраслевым стандартом промышленной разработки программного обеспечения. По данным ежегодного исследования GitLab «Global DevSecOps Report», подавляющее большинство организаций, применяющих гибкие методологии, используют автоматизированные конвейеры сборки и развёртывания [14]; аналогичную картину фиксирует опрос JetBrains «The State of Developer Ecosystem», согласно которому доля разработчиков, применяющих системы непрерывной интеграции, превышает 60 % и продолжает расти [15]. Автоматизация процессов разработки повышает скорость поставки, однако одновременно превращает конвейер в критический элемент инфраструктуры, обладающий широкими полномочиями и высоким уровнем доверия.

Уровень доверия к конвейеру определяется частотой и автоматизмом его работы: согласно отчёту DORA «Accelerate State of DevOps», зрелые команды выполняют развёртывание в промышленную среду по требованию, вплоть до нескольких раз в день, без ручного контроля каждого выпуска [16]. В таких условиях конвейер фактически замещает оператора при принятии решения о допуске программного обеспечения в промышленную среду, а значит его компрометация даёт нарушителю возможность легитимной, с точки зрения системы защиты, доставки вредоносного кода. Дополнительным фактором расширения поверхности атаки служит практика описания конвейера в виде кода (pipeline-as-code) и управления инфраструктурой через репозиторий (GitOps): определение процесса сборки и развёртывания хранится и изменяется наравне с исходным кодом, поэтому недостатки управления доступом к репозиторию непосредственно транслируются в возможность модификации самого конвейера.

Архитектурно корпоративная DevOps-инфраструктура представляет собой конвейер, объединяющий последовательность технологических этапов, каждый из

которых обладает собственным набором полномочий и передаёт результат работы следующему этапу. В обобщённом виде конвейер образует цепочку доверия: система контроля версий (репозиторий исходного кода и определения конвейера) → система сборки (среда исполнения заданий, исполнители сборки) → подсистема подключения внешних зависимостей → хранилище артефактов и реестр образов → хранилище секретов → среда развёртывания (промышленная среда). Ключевой особенностью этой цепочки является наследование доверия: результат работы предшествующего этапа принимается последующим как доверенный без повторной проверки, поэтому компрометация раннего этапа автоматически распространяется на все последующие вплоть до промышленной среды [8].

Каждый этап конвейера выполняет обособленную роль в цепочке доверия. Репозиторий исходного кода выступает источником истины: он хранит как код, так и определение конвейера, поэтому доверие ко всем последующим этапам восходит к целостности репозитория. Система сборки является средой исполнения: она обрабатывает код и зависимости с высокими полномочиями и потому наиболее чувствительна к исполнению недоверенного содержимого. Хранилище артефактов и реестр образов выполняют роль пункта распространения, хранилище секретов — источника полномочий, а среда развёртывания — конечного шлюза допуска программного обеспечения в промышленную эксплуатацию.

Границы доверия проходят между смежными этапами и определяют точки, в которых результат предшествующего этапа должен проверяться последующим. На практике такие проверки часто отсутствуют: артефакт принимается на развёртывание без верификации подписи, зависимость подключается без проверки источника, задание сборки исполняет код из непроверенной ветви. Отсутствие контроля на границе доверия означает, что компрометация, возникшая на одном этапе, беспрепятственно пересекает границу и наследуется следующим, — именно это свойство делает недостаточной изолированную оценку отдельных этапов и требует построения дерева угроз, охватывающего конвейер целиком.

Для построения дерева угроз объект защиты декомпозируется на активы, каждому из которых сопоставляются назначение, типовые недостатки безопасности

и профильный класс риска по классификации OWASP Top 10 CI/CD Security Risks. Результат декомпозиции приведён в таблице 1.

Таблица 1 – Декомпозиция CI/CD-конвейера на активы

Актив (этап конвейера)	**Назначение**	**Типовые недостатки безопасности**	**Класс OWASP**
Репозиторий исходного кода	Хранение кода и определения конвейера (pipeline-as-code)	Слабое управление доступом, отсутствие защиты веток, секреты в истории	CICD-SEC-1, 2, 6
Система сборки (исполнители)	Исполнение заданий сборки и тестирования	Избыточные права исполнителя, исполнение недоверенного кода, слабая изоляция	CICD-SEC-4, 5, 7
Подключение зависимостей	Загрузка сторонних пакетов и образов	Dependency confusion, отсутствие фиксации версий, недоверенные источники	CICD-SEC-3
Хранилище артефактов и реестр	Хранение и выдача собранных артефактов	Отсутствие проверки целостности и подписи артефактов	CICD-SEC-9
Хранилище секретов	Выдача учётных данных конвейеру	Долгоживущие токены, избыточная область действия, секреты в логах	CICD-SEC-6
Среда развёртывания	Приём и запуск артефакта в промышленной среде	Развёртывание без проверки подписи, избыточные права доставки	CICD-SEC-9, 5

Таблица 1 выполняет три функции: задаёт границы объекта защиты, служит перечнем узлов для построения дерева угроз (подраздел 1.6) и обеспечивает требуемую методикой конкретность объекта, без которой дерево угроз повисает в воздухе.

Модель эксплуатации объекта описывает типовую последовательность действий нарушителя вдоль цепочки доверия и отражает связный характер конвейера. Начальный доступ достигается одним из трёх способов: внедрением вредоносного кода через скомпрометированную стороннюю зависимость, отравляющим исполнением конвейера (Poisoned Pipeline Execution) при обработке недоверенного кода в среде сборки либо использованием утёкшего секрета конвейера. Получив исполнение в среде сборки, нарушитель обращается к секретам конвейера и повышает свои полномочия; далее он воздействует на целостность собираемого артефакта и, наследуя доверие последующих этапов, добивается развёртывания подменённого артефакта или прямого доступа в промышленную

среду. Таким образом, единичный недостаток раннего этапа реализуется как цепочка рисков, а не как изолированное событие, что определяет необходимость учёта распространения компрометации при оценке риска.

Модель нарушителя сформирована в соответствии с Методикой оценки угроз безопасности информации ФСТЭК России [13]. Внешний нарушитель воздействует на конвейер опосредованно — через компрометацию сторонней зависимости, публичного реестра пакетов или внешнего сервиса, подключённого к конвейеру; его потенциал оценивается как базовый повышенный. Внутренний нарушитель — разработчик с правом отправки изменений либо лицо, сопровождающее конвейер, — способен модифицировать определение конвейера, инициировать исполнение недоверенного кода и получить доступ к секретам; его потенциал оценивается как высокий. Оба типа нарушителя преследуют цели внедрения вредоносного кода в поставляемый продукт, получения доступа в промышленную среду и нарушения целостности артефактов.

1.2 Недостатки безопасности CI/CD-процессов как источник риска и их отличие от уязвимостей программного кода

Центральной особенностью рассматриваемого объекта является природа его недостатков безопасности. Уязвимость программного кода представляет собой дефект реализации конкретного программного продукта; она получает идентификатор в реестре уязвимостей (CVE в базе NVD [17] или запись в банке данных угроз ФСТЭК России [18]), характеризуется вектором CVSS [19] и накопленной статистикой эксплуатации, отражаемой оценкой EPSS [20], и устраняется установкой исправления (патча). Недостаток безопасности CI/CD-процесса имеет иную природу: он порождается не дефектом кода, а организацией конвейера — объёмом полномочий исполнителя сборки, порядком подключения зависимостей, условиями запуска заданий, сроком жизни и областью действия секретов, наличием либо отсутствием проверки подписи артефактов.

Из этого различия следует практически значимое обстоятельство: недостаток безопасности конвейера не получает идентификатора уязвимости, для него не

определён вектор CVSS, и он не принимается на вход оценкой EPSS. Формально такой недостаток нечего поместить в традиционный риск-анализ, ориентированный на уязвимости с присвоенным идентификатором. Сопоставление двух классов недостатков приведено в таблице 2.

Таблица 2 – Отличие недостатков безопасности CI/CD-процессов от уязвимостей программного кода

Признак	**Уязвимость программного кода**	**Недостаток безопасности CI/CD-процесса**
Природа	Дефект реализации продукта	Свойство организации конвейера
Идентификатор	CVE (NVD, БДУ ФСТЭК)	Отсутствует
Оценка критичности	Вектор CVSS, оценка EPSS	Не определена стандартными калькуляторами
Способ обнаружения	Сканеры SAST, SCA, анализ состава	Проверка конфигурации и политик конвейера
Способ устранения	Установка исправления (патч)	Изменение конфигурации и процесса
Учёт в риск-анализе	Штатный	Выпадает из анализа

Различие в природе недостатков определяет и различие в способе их устранения. Уязвимость программного кода устраняется установкой исправления, выпускаемого поставщиком, тогда как недостаток безопасности конвейера устраняется изменением его организации — сокращением срока жизни секретов, ограничением полномочий исполнителя, внедрением проверки подписи артефактов. Такое устранение не является разовым: любое изменение конфигурации конвейера способно как закрыть, так и открыть недостаток, поэтому оценка риска должна не фиксироваться однократно, а переоцениваться при изменении инфраструктуры. Это обстоятельство обосновывает потребность в непрерывной переоценке риск-ландшафта, вынесенную в отдельную задачу исследования.

Указанное различие объясняет ограниченность существующих средств анализа защищённости, ориентированных преимущественно на уязвимости программного кода. Средства статического анализа кода (SAST) и анализа состава программного обеспечения (SCA) выявляют дефекты в исходном коде и известные уязвимости в зависимостях, но не оценивают организацию конвейера; средства

обнаружения секретов фиксируют факт утечки, но не переводят его в меру риска. Сопоставление наиболее близких к предмету исследования средств приведено в таблице 3.

Таблица 3 – Анализ средств-аналогов

Средство	Что обеспечивает	Чего не обеспечивает
Checkov [21]	Проверку конфигурации инфраструктуры на соответствие политикам	Перевода в меру риска и учёта связности конвейера
Snyk [22]	Обнаружение известных уязвимостей в зависимостях и образах	Оценки недостатков организации конвейера, меры риска
GitGuardian [5]	Обнаружение секретов в коде и истории репозитория	Оценки ущерба от компрометации секрета, меры риска
Trivy [23]	Поиск уязвимостей и мисконфигураций	Риск-ландшафта и распространения компрометации
SLSA / in-toto [10, 24]	Подтверждение происхождения (provenance) артефакта	Это контроль соответствия, а не анализ риска
Sigstore / cosign [25]	Подпись и проверку целостности артефактов	Количественной оценки риска и приоритизации

Практическую значимость этого различия подтверждают известные инциденты. При компрометации сервиса Codecov в 2021 году нарушитель изменил сценарий загрузки покрытия (Bash Uploader), исполнявшийся в конвейерах множества организаций, и в течение нескольких месяцев собирал попадавшие в среду сборки секреты; дефекта в коде продукта при этом не было — использовался недостаток организации доверия к внешнему сценарию конвейера [26]. В атаке на SolarWinds нарушитель внедрил вредоносный код на этапе сборки, вследствие чего подписанный и легитимно распространённый артефакт содержал закладку [2]. Оба случая иллюстрируют, что источником ущерба выступает не уязвимость программного кода, а недостаток безопасности процесса его сборки и поставки, не имеющий идентификатора уязвимости.

Общий вывод: существующие средства дают дискретную, как правило бинарную, оценку соответствия отдельного требования, не переводят её в меру риска, не учитывают связность конвейера и наследование компрометации последующими этапами и не переоценивают состояние при изменении

конфигурации. Эти пробелы образуют пространство противоречий, разрешаемых в работе, и обосновывают необходимость построения собственной модели угроз объекта.

1.3 Нормативно-правовое обеспечение защиты DevOps-инфраструктуры и требования к безопасности конвейера

Требования к защищённости объекта задаются двумя группами документов — национальными нормативными правовыми актами и стандартами Российской Федерации, а также международными отраслевыми стандартами безопасной разработки. Национальную группу образуют требования ФСТЭК России по защите информации в государственных информационных системах [27] и по обеспечению безопасности значимых объектов критической информационной инфраструктуры [28], Методика оценки угроз безопасности информации [13], а также национальные стандарты менеджмента информационной безопасности [29], менеджмента риска [30] и классификации уязвимостей информационных систем [31], относящей к отдельному классу уязвимости конфигурации — прямой аналог рассматриваемых недостатков конвейера.

Отраслевую группу образуют практики безопасной разработки программного обеспечения NIST SP 800-218 (Secure Software Development Framework) [9], специализированные рекомендации по интеграции безопасности цепочки поставки в конвейеры CI/CD NIST SP 800-204D [32], спецификация уровней зрелости цепочки поставки SLSA [10] и профильный перечень OWASP Top 10 CI/CD Security Risks [8]. В отличие от национальных документов, устанавливающих преимущественно организационные требования, отраслевые стандарты детализируют технические требования кпроцессу сборки и поставки. Сопоставление документов и предъявляемых ими требований к конвейеру приведено в таблице 4.

Таблица 4 – Нормативно-правовое обеспечение защиты объекта

Документ	Область регулирования	Требование к конвейеру
Приказ ФСТЭК России № 17	Защита информации в ГИС	Управление доступом, регистрация событий безопасности
Приказ ФСТЭК России № 239	Безопасность объектов КИИ	Контроль целостности и доверенная загрузка ПО
Методика оценки угроз ФСТЭК	Моделирование угроз	Определение нарушителя и сценариев эксплуатации
ГОСТ Р ИСО/МЭК 27005	Менеджмент риска ИБ	Оценка и обработка рисков
ГОСТ Р 56546	Классификация уязвимостей	Учёт уязвимостей конфигурации
NIST SP 800-218 (SSDF)	Безопасная разработка ПО	Защита среды сборки, проверка зависимостей
NIST SP 800-204D	Безопасность CI/CD	Защита конвейера и цепочки поставки
SLSA	Целостность артефактов	Подтверждение происхождения и подписи

Согласно требованиям к оформлению и защите работ, контроль соблюдения требований к безопасности возлагается на разработчика и проверяющее лицо, однако ни один из перечисленных документов не устанавливает измеримого критерия защищённости конвейера. Национальные акты формулируют требования на уровне организационных мер (управление доступом, регистрация событий, контроль целостности), тогда как отраслевые стандарты детализируют технические меры, но оставляют их приоритизацию на усмотрение организации. Разрыв между качественными требованиями и потребностью в количественной оценке риска и составляет методическую предпосылку настоящей работы.

Совместный анализ документов показывает, что требования к безопасности конвейера рассредоточены по нескольким источникам разной юридической силы и природы, сформулированы преимущественно качественно и не сопровождаются методикой количественной оценки риска. Это подтверждает необходимость сведения требований к единой базе недостатков и разработки методики их количественной оценки.

1.4 Информационные источники сведений о недостатках безопасности CI/CD и их сопоставление с техниками MITRE ATT&CK

Информационное обеспечение анализа угроз образуют базы знаний о недостатках безопасности процессов разработки и о техниках их эксплуатации. Профильным источником сведений о недостатках выступает перечень OWASP Top 10 CI/CD Security Risks, систематизирующий десять классов рисков конвейера: недостаточное управление потоком изменений (CICD-SEC-1), ненадлежащее управление идентификацией и доступом (CICD-SEC-2), злоупотребление цепочкой зависимостей (CICD-SEC-3), отравляющее исполнение конвейера (CICD-SEC-4), недостаточное управление правами исполнителей (CICD-SEC-5), недостаточная гигиена учётных данных (CICD-SEC-6), небезопасная конфигурация системы (CICD-SEC-7), неконтролируемое использование сторонних сервисов (CICD-SEC-8), ненадлежащая проверка целостности артефактов (CICD-SEC-9) и недостаточные журналирование и наблюдаемость (CICD-SEC-10) [8].

Дополняющими источниками служат практики безопасной разработки NIST SP 800-218 [9] и рекомендации NIST SP 800-204D по защите конвейеров [32], спецификация SLSA в части происхождения артефактов [10], перечень типов недостатков CWE [33] и каталог шаблонов атак CAPEC [34]. Сведения о техниках эксплуатации предоставляет матрица MITRE ATT&CK [11], описывающая тактики и техники, применяемые нарушителем. Реестры уязвимостей готового программного обеспечения (NVD, банк данных угроз ФСТЭК России) применимы ограниченно, поскольку описывают дефекты продуктов, а не организацию конвейера. Систематизация источников приведена в таблице 5.

Таблица 5 – Источники знаний и их применимость к объекту

Источник	**Что описывает**	**Применимость к CI/CD-конвейеру**
OWASP Top 10 CI/CD Security Risks	Десять классов рисков конвейера (CICD-SEC-1…10)	Профильная классификация недостатков по этапам
NIST SP 800-218 (SSDF)	Практики безопасной разработки ПО	Источник контрольных точек процесса
NIST SP 800-204D	Безопасность конвейеров CI/CD	Меры защиты цепочки поставки в конвейере

Продолжение таблицы 5

Источник	Что описывает	Применимость к CI/CD-конвейеру
SLSA	Уровни зрелости, происхождение артефактов	Требования к целостности артефактов
CWE / CAPEC	Типы недостатков и шаблоны атак	Классификация первопричин и способов атаки
MITRE ATT&CK	Тактики и техники атак	Сопоставление недостатка с техникой эксплуатации
NVD, БДУ ФСТЭК России	Уязвимости готового ПО	Ограниченно: не описывают организацию конвейера

Отдельного внимания заслуживают классы, связанные с конфигурацией и наблюдаемостью конвейера. Небезопасная конфигурация системы (CICD-SEC-7) охватывает применение небезопасных значений по умолчанию и избыточных сетевых доступов в компонентах конвейера; неконтролируемое использование сторонних сервисов (CICD-SEC-8) описывает предоставление внешним интеграциям избыточных прав в репозитории и конвейере; недостаточные журналирование и наблюдаемость (CICD-SEC-10) лишают организацию возможности выявить факт компрометации и восстановить цепочку действий нарушителя. Перечисленные классы редко приводят к ущербу самостоятельно, однако повышают вероятность реализации системообразующих угроз и затрудняют их обнаружение, поэтому учитываются при оценке вероятности в риск-ландшафте.

Ключевой операцией информационного обеспечения является сопоставление недостатков безопасности конвейера с техниками их эксплуатации по матрице MITRE ATT&CK. Такое сопоставление переводит качественное описание недостатка в конкретную технику с наблюдаемыми признаками, что необходимо как для оценки вероятности эксплуатации, так и для последующего выявления инцидентов. Результат сопоставления профильных классов OWASP с техниками ATT&CK приведён в таблице 6.

Таблица 6 – Сопоставление классов OWASP с техниками MITRE ATT&CK

Класс OWASP	Недостаток	Техника ATT&CK	Тактика
CICD-SEC-3	Злоупотребление цепочкой зависимостей	T1195.001	Первоначальный доступ
CICD-SEC-3	Компрометация цепочки поставки ПО	T1195.002	Первоначальный доступ

Продолжение таблицы 6

Класс OWASP	Недостаток	Техника ATT&CK	Тактика
CICD-SEC-4	Отравляющее исполнение конвейера	T1059	Выполнение
CICD-SEC-6	Учётные данные в файлах и логах	T1552.001	Доступ к учётным данным
CICD-SEC-6	Приватные ключи	T1552.004	Доступ к учётным данным
CICD-SEC-9	Перехват потока выполнения	T1574	Закрепление / эскалация
CICD-SEC-9	Компрометация двоичного файла	T1554	Закрепление
CICD-SEC-5	Злоупотребление действительной учётной записью	T1078	Эскалация привилегий

Каталоги CAPEC и CWE обеспечивают дополнительную детализацию сопоставления. Так, злоупотреблению цепочкой зависимостей соответствует шаблон атаки CAPEC-437 (Undermining Security through Compromised Software Supply Chain) [34], а первопричина описывается типом недостатка CWE-1104 (Use of Unmaintained Third Party Components) [33]; недостаточной гигиене учётных данных соответствует CWE-798 (Use of Hard-coded Credentials). Привязка каждого недостатка к паре «шаблон атаки — тип недостатка» повышает воспроизводимость базы соответствий и облегчает её последующее пополнение независимыми специалистами.

Сопоставление показывает, что недостатки безопасности конвейера реализуются техниками первоначального доступа, выполнения и доступа к учётным данным, преимущественно классов «компрометация цепочки поставки» и «незащищённые учётные данные». Это подтверждает выбор системообразующих угроз, используемых при построении дерева угроз в подразделе 1.6.

1.5 Формирование базы соответствий «недостаток безопасности этапа конвейера — эксплуатирующая техника — наступающий ущерб»

На основе систематизированных источников формируется структурированная база соответствий, связывающая каждый недостаток безопасности с этапом

конвейера, эксплуатирующей техникой MITRE ATT&CK и наступающим ущербом. База является решением первой задачи исследования и информационной основой для количественной оценки риска и построения дерева угроз. Структура базы приведена в таблице 7; полная версия вынесена в приложение А.

Таблица 7 – База соответствий «недостаток — техника — ущерб» (фрагмент)

Этап конвейера	**Недостаток (OWASP)**	**Техника (ATT&CK)**	**Наступающий ущерб**
Репозиторий кода	Отсутствие защиты веток (CICD-SEC-1)	T1195.002	Обход контроля потока изменений
Репозиторий кода	Секрет в истории репозитория (CICD-SEC-6)	T1552.001	Раскрытие учётных данных конвейера
Подключение зависимостей	Dependency confusion (CICD-SEC-3)	T1195.001	Внедрение вредоносного кода в сборку
Подключение зависимостей	Недоверенный источник пакетов (CICD-SEC-3)	T1195.002	Компрометация цепочки поставки
Система сборки	Исполнение недоверенного кода — PPE (CICD-SEC-4)	T1059	Исполнение произвольного кода в исполнителе
Система сборки	Избыточные права исполнителя (CICD-SEC-5)	T1078	Повышение полномочий, боковое перемещение
Хранилище секретов	Долгоживущий токен (CICD-SEC-6)	T1552.001	Доступ в промышленную среду
Хранилище секретов	Приватный ключ в конфигурации (CICD-SEC-6)	T1552.004	Подмена доверенных артефактов
Хранилище артефактов	Отсутствие проверки подписи (CICD-SEC-9)	T1574	Развёртывание подменённого артефакта
Хранилище артефактов	Компрометация двоичного файла (CICD-SEC-9)	T1554	Внедрение закладки в поставляемый продукт
Среда развёртывания	Избыточные права доставки (CICD-SEC-5)	T1078	Прямой доступ в промышленную среду
Наблюдаемость	Недостаточное журналирование (CICD-SEC-10)	T1562	Сокрытие следов, затруднение расследования

Методика построения базы включает четыре шага. На первом шаге из профильных источников (OWASP Top 10 CI/CD Security Risks, NIST SP 800-218 и NIST SP 800-204D) извлекается перечень недостатков безопасности и выполняется их привязка к этапам конвейера в соответствии с декомпозицией объекта (таблица 1.1). На втором шаге каждому недостатку сопоставляется эксплуатирующая техника по матрице MITRE ATT&CK, при необходимости уточняемая шаблоном атаки CAPEC [34] и типом недостатка CWE [33]. На третьем шаге определяется наступающий ущерб исходя из достижимого нарушителем результата — от

раскрытия учётных данных до доступа в промышленную среду. На четвёртом шаге тройки консолидируются в единую структуру, пригодную для машинной обработки.

Сформированная база выполняет двойную функцию. При оценке риска она служит признаковым пространством: перечень недостатков конвейера с привязкой к этапу и технике образует набор признаков, по которым интеллектуальный блок системы восстанавливает недостающую оценку критичности, отсутствующую в стандартных калькуляторах. При выявлении инцидентов сопоставление недостатка с техникой MITRE ATT&CK задаёт наблюдаемые признаки компрометации, используемые при формировании регламентов противодействия в последующих главах. Тем самым база соответствий связывает аналитическую и практическую части работы.

База построена как множество троек и допускает пополнение по мере развития источников знаний. Каждая тройка связывает организационный недостаток с наблюдаемой техникой и конкретным видом ущерба, что позволяет в дальнейшем присвоить недостатку количественную меру риска, минуя отсутствующий идентификатор уязвимости.

Для последующей машинной обработки база представляется в табличной форме, в которой каждая строка соответствует одной тройке, а столбцы фиксируют этап конвейера, недостаток с указанием класса OWASP, эксплуатирующую технику ATT&CK и наступающий ущерб. Такое представление позволяет использовать базу как размеченное признаковое пространство при обучении модели оценки риска и одновременно как справочник при ручном анализе защищённости конвейера. Единообразие структуры обеспечивает сопоставимость оценок между различными конвейерами организации.

1.6 Классификация недостатков безопасности CI/CD и построение дерева угроз и индуцированных ими рисков

Для упорядочения множества недостатков и перехода к дереву угроз проводится их классификация по двум основаниям: по этапу конвейера, на котором проявляется недостаток, и по нарушаемому свойству безопасности процесса. Классификация приведена в таблице 8.

Таблица 8 – Классификация недостатков безопасности CI/CD-процессов

Нарушаемое свойство	Характерные недостатки	Класс OWASP
Управление доступом	Слабая защита веток, избыточные права исполнителя	CICD-SEC-1, 2, 5
Целостность цепочки поставки	Недоверенные зависимости, подмена артефакта	CICD-SEC-3, 9
Изоляция исполнения	Отравляющее исполнение, слабая изоляция исполнителя	CICD-SEC-4, 7
Гигиена секретов	Долгоживущие и избыточные учётные данные	CICD-SEC-6
Наблюдаемость	Недостаточные журналирование и мониторинг	CICD-SEC-10

На основе классификации выделены четыре системообразующие угрозы, объединяющие недостатки по механизму реализации: У1 — компрометация цепочки зависимостей; У2 — компрометация (утечка) секретов конвейера; У3 — подмена артефакта и нарушение его целостности; У4 — злоупотребление правами исполнителя сборки. В соответствии с первым тактом методики [12] построено дерево угроз и индуцированных ими рисков: корнем выступает нарушение безопасности конвейера, от которого ветвятся системообразующие угрозы, а от них — цепочки рисков, узлы которых соответствуют активам таблицы 1. Дерево приведено на рисунке 1.

Угроза У1 — компрометация цепочки зависимостей — реализуется на этапе подключения внешних пакетов и образов. Нарушитель добивается включения в сборку вредоносного компонента одним из способов: публикацией вредоносного пакета под именем, близким к легитимному (typosquatting), использованием приоритета внутреннего имени во внешнем реестре (dependency confusion) либо компрометацией сопровождающего популярной библиотеки. Поскольку зависимости подключаются автоматически и наследуют доверие сборки, внедрённый код исполняется с полномочиями конвейера, а его последствия распространяются на все собираемые артефакты. Цепочка рисков угрозы включает внедрение вредоносного кода (критический уровень), подмену пакета (высокий) и неконтролируемую транзитивную зависимость (средний).

Угроза У2 — компрометация секретов конвейера — реализуется на этапе доступа заданий к учётным данным. Долгоживущие токены с избыточной областью действия, секреты, попадающие в журналы сборки или историю репозитория, и приватные ключи в конфигурации образуют множество точек утечки. Компрометация секрета, обеспечивающего доступ в промышленную среду, ведёт к прямому проникновению в защищаемую систему в обход средств защиты периметра. Цепочка рисков включает доступ в промышленную среду по утёкшему токену (критический уровень), раскрытие секрета в журналах и истории (высокий) и избыточную область действия сервисной учётной записи (высокий).

Угроза У3 — подмена артефакта и нарушение его целостности — реализуется на этапах хранения артефактов и развёртывания. Между сборкой и развёртыванием артефакт может быть подменён, если его происхождение не подтверждено, а подпись не проверяется на этапе выпуска в промышленную среду. Отсутствие воспроизводимости сборки лишает организацию возможности доказать, что развёрнутый артефакт соответствует проверенному исходному коду. Цепочка рисков включает подмену артефакта между сборкой и развёртыванием (критический уровень), развёртывание без проверки подписи (высокий) и невозможность подтвердить происхождение при невоспроизводимой сборке (средний).

Угроза У4 — злоупотребление правами исполнителя сборки — реализуется на этапе исполнения заданий. Обработка недоверенного кода в среде сборки (отравляющее исполнение конвейера) позволяет нарушителю исполнить произвольный код с полномочиями исполнителя, а слабая изоляция исполнителей — переместиться к смежным проектам организации. Возможность модификации определения конвейера превращает разовое воздействие в устойчивое присутствие. Цепочка рисков включает исполнение произвольного кода в привилегированном исполнителе (критический уровень), несанкционированную модификацию определения конвейера (высокий) и боковое перемещение из-за слабой изоляции (высокий).

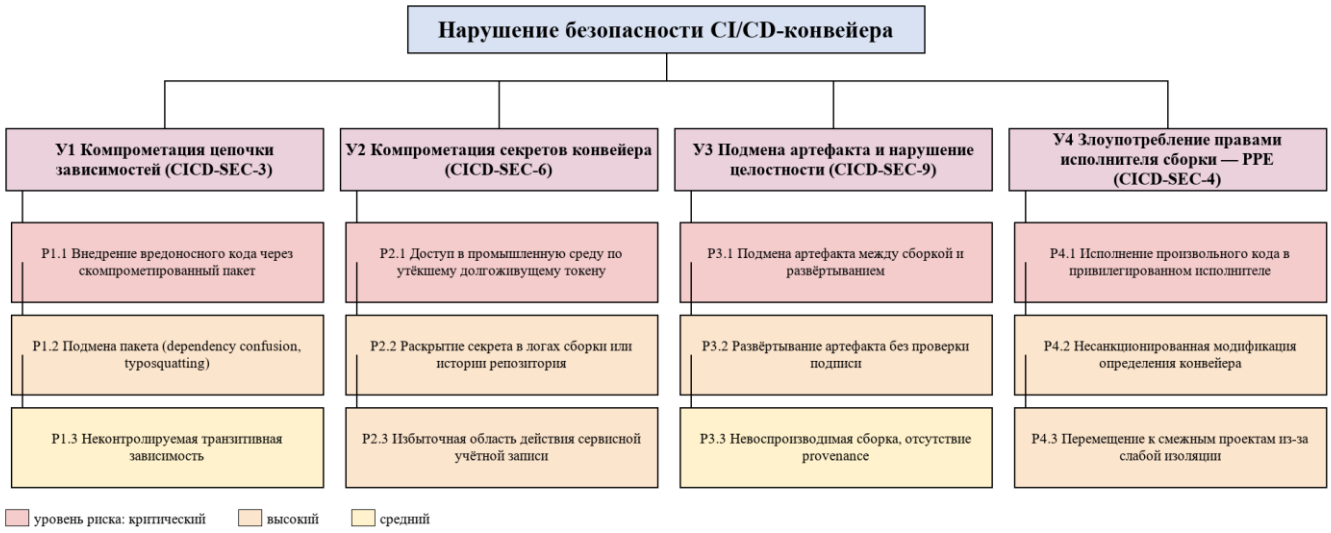


Рисунок 1 – Дерево угроз и индуцированных рисков CI/CD-конвейера

Вероятность успешной эксплуатации P оценивается по пятиуровневой порядковой шкале, приводимой к отрезку от нуля до единицы, и учитывает три фактора: распространённость соответствующей техники по данным MITRE ATT&CK и отраслевой статистики, доступность недостатка для нарушителя выделенных категорий и наличие компенсирующих мер контроля на границе доверия. Величина ущерба U нормируется по достижимому нарушителем результату: значение, близкое к единице, присваивается рискам, ведущим к внедрению кода в поставляемый продукт или к прямому доступу в промышленную среду, промежуточные значения — рискам раскрытия учётных данных и нарушения целостности артефактов, меньшие значения — рискам, ограниченным одним этапом конвейера.

Мера риска вычисляется как произведение вероятности успешной эксплуатации P на нормированную величину ущерба U по формуле $R = P \times U$, что соответствует определению меры риска [12]. Значения вероятности получены экспертной оценкой с опорой на распространённость соответствующих техник по данным MITRE ATT&CK [11] и отраслевую статистику инцидентов цепочки поставки [35]; величина ущерба нормирована по достижимости промышленной среды.

Распределение рисков по уровням показывает, что критический уровень сосредоточен на ранних этапах цепочки доверия — подключении зависимостей,

хранилище секретов и системе сборки, тогда как на этапах хранения артефактов и развёртывания преобладают риски высокого уровня. Такое распределение отражает свойство наследования компрометации: чем раньше по цепочке расположен недостаток, тем большее число последующих этапов наследует его последствия и тем выше нормированная величина ущерба. Это подтверждает необходимость учёта распространения компрометации при количественной оценке риска, вынесенного в отдельную задачу исследования.

Максимальную меру риска образуют риски, ведущие соответственно к внедрению вредоносного кода, доступу в промышленную среду и исполнению произвольного кода в исполнителе сборки; они требуют первоочередного регулирования. Именно эти риски не переводятся в меру риска существующими средствами анализа (подраздел 1.2), которые фиксируют отдельные недостатки, но не учитывают их связность и распространение по цепочке доверия. Тем самым построенная модель угроз выявляет пробелы существующих подходов, формализованные во введении как противоречия исследования.

В отличие от результатов работы существующих средств анализа, дающих бинарный вердикт о соответствии отдельного требования, риск-ландшафт представляет защищённость конвейера как упорядоченное по мере риска множество, в котором каждый риск связан с конкретным этапом, техникой и величиной возможного ущерба. Это позволяет перейти от перечня несоответствий к обоснованной приоритизации: первоочередному регулированию подлежат риски критического уровня, сосредоточенные на ранних этапах цепочки доверия, поскольку их устранение снижает и производные риски последующих этапов.

Риск-ландшафт служит основой для последующих задач исследования. Ранжирование рисков по мере R задаёт порядок разработки мер противодействия; значения вероятности и ущерба, полученные для отдельных недостатков, образуют исходные данные для методики количественной оценки критичности; а зависимость меры риска от конфигурации конвейера обосновывает необходимость её непрерывной переоценки при изменении инфраструктуры. Таким образом, построенная в настоящем подразделе модель замыкает аналитическую часть работы и определяет содержание её последующих глав.

1.7 Выводы по первой главе

В первой главе построена модель угроз корпоративной DevOps-инфраструктуры, реализующей процессы непрерывной интеграции и поставки программного обеспечения. Получены следующие результаты.

1 Объект защиты — CI/CD-конвейер — представлен как цепочка доверия и декомпозирован на активы (таблица 1); описаны модель эксплуатации, отражающая связный характер конвейера, и модель нарушителя по методике ФСТЭК России.

2 Недостатки безопасности CI/CD-процессов отделены от уязвимостей программного кода (таблица 2): показано, что недостаток конвейера не получает идентификатора уязвимости, не имеет вектора CVSS и не принимается оценкой EPSS, вследствие чего выпадает из традиционного риск-анализа, а существующие средства-аналоги (таблица 3) не переводят его в меру риска.

3 Систематизированы информационные источники сведений о недостатках (таблица 5) и выполнено их сопоставление с техниками MITRE ATT&CK (таблица 6); на этой основе сформирована база соответствий «недостаток — техника — ущерб» (таблица 7, приложение А), являющаяся решением первой задачи исследования.

4 Проведена классификация недостатков (таблица 8), построено дерево угроз и индуцированных рисков (рисунок 1).

Научная значимость результатов главы состоит в том, что недостатки безопасности впервые отнесены не к средствам автоматизации сборки как к программным продуктам, а к этапам конвейера как к звеньям цепочки доверия, обладающим собственным набором полномочий, а построенное дерево угроз учитывает наследование компрометации по цепочке. Практическая значимость состоит в том, что база соответствий и риск-ландшафт применимы при проектировании защиты DevOps-инфраструктуры как перечень контролируемых точек конвейера с указанием техники эксплуатации и ожидаемого ущерба.

Полученные результаты образуют информационное и модельное обеспечение для количественной оценки и регулирования киберрисков и составляют содержание первой главы выпускной квалификационной работы. Последующие задачи, поставленные во введении, решаются в следующих главах.

СПИСОК ЛИТЕРАТУРЫ

1. State of the Software Supply Chain : 9th Annual Report / Sonatype. 2023. URL: https://www.sonatype.com/state-of-the-software-supply-chain (дата обращения: 15.09.2026).

2. Highly Evasive Attacker Leverages SolarWinds Supply Chain (SUNBURST) : Threat Research Report / Mandiant. 2020. URL: https://www.mandiant.com (дата обращения: 15.09.2026).

3. CVE-2024-3094 : Malicious code in XZ Utils : National Vulnerability Database / NIST. 2024. URL: https://nvd.nist.gov/vuln/detail/CVE-2024-3094 (дата обращения: 15.09.2026).

4. 2024 Data Breach Investigations Report / Verizon. 2024. URL: https://www.verizon.com/business/resources/reports/dbir (дата обращения: 15.09.2026).

5. The State of Secrets Sprawl 2024 / GitGuardian. 2024. URL: https://www.gitguardian.com/state-of-secrets-sprawl-report-2024 (дата обращения: 15.09.2026).

6. Актуальные киберугрозы: итоги 2024 года и I–II кварталов 2025 года / Positive Technologies. 2025. URL: https://www.ptsecurity.com/ru-ru/research/analytics (дата обращения: 15.09.2026).

7. Cost of a Data Breach Report 2024 / IBM Security, Ponemon Institute. 2024. URL: https://www.ibm.com/reports/data-breach (дата обращения: 15.09.2026).

8. OWASP Top 10 CI/CD Security Risks / OWASP Foundation. 2023. URL: https://owasp.org/www-project-top-10-ci-cd-security-risks (дата обращения: 15.09.2026).

9. Souppaya M., Scarfone K., Dodson D. Secure Software Development Framework (SSDF) Version 1.1 : NIST Special Publication 800-218. Gaithersburg : NIST, 2022. 36 p.

10. Supply-chain Levels for Software Artifacts (SLSA) : Specification v1.0 / Open Source Security Foundation. 2023. URL: https://slsa.dev (дата обращения: 15.09.2026).

11. MITRE ATT&CK : Enterprise Matrix / The MITRE Corporation. 2025. URL: https://attack.mitre.org (дата обращения: 15.09.2026).

12. Краткие научно-методические рекомендации по формированию и выполнению технических заданий в области обеспечения информационной безопасности / А. Г. Остапенко, М. Е. Волкова, Д. А. Нархов [и др.] // Информация и безопасность. 2020. Т. 23, вып. 4. С. 551–560.

13. Методика оценки угроз безопасности информации : утверждена ФСТЭК России 5 февраля 2021 г. URL: https://fstec.ru (дата обращения: 15.09.2026).

14. Global DevSecOps Report / GitLab Inc. 2024. URL: https://about.gitlab.com/developer-survey (дата обращения: 15.09.2026).

15. The State of Developer Ecosystem 2024 / JetBrains s.r.o. 2024. URL: https://www.jetbrains.com/lp/devecosystem-2024 (дата обращения: 15.09.2026).

16. Accelerate State of DevOps Report / DORA, Google Cloud. 2024. URL: https://dora.dev (дата обращения: 15.09.2026).

17. National Vulnerability Database / NIST. 2025. URL: https://nvd.nist.gov (дата обращения: 15.09.2026).

18. Банк данных угроз безопасности информации / ФСТЭК России, ГНИИИ ПТЗИ. 2025. URL: https://bdu.fstec.ru (дата обращения: 15.09.2026).

19. Common Vulnerability Scoring System version 4.0 : Specification Document / FIRST.org. 2023. URL: https://www.first.org/cvss/v4-0 (дата обращения: 15.09.2026).

20. Exploit Prediction Scoring System (EPSS) : Model and Data / FIRST.org. 2024. URL: https://www.first.org/epss (дата обращения: 15.09.2026).

21. Checkov : Policy-as-code for infrastructure : Documentation / Prisma Cloud, Bridgecrew. 2025. URL: https://www.checkov.io (дата обращения: 15.09.2026).

22. Snyk Developer Security Platform : Documentation / Snyk Ltd. 2025. URL: https://docs.snyk.io (дата обращения: 15.09.2026).

23. Trivy : Comprehensive security scanner : Documentation / Aqua Security. 2025. URL: https://trivy.dev (дата обращения: 15.09.2026).

24. in-toto : A framework to secure the integrity of software supply chains : Specification / Open Source Security Foundation. 2024. URL: https://in-toto.io (дата обращения: 15.09.2026).

25. Sigstore : A new standard for signing, verifying and protecting software / Open Source Security Foundation. 2024. URL: https://www.sigstore.dev (дата обращения: 15.09.2026).

26. Codecov Security Update: Bash Uploader Incident / Codecov. 2021. URL: https://about.codecov.io/security-update (дата обращения: 15.09.2026).

27. Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах : приказ ФСТЭК России от 11 февраля 2013 г. № 17. URL: https://fstec.ru (дата обращения: 15.09.2026).

28. Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации : приказ ФСТЭК России от 25.12.2017 № 239. URL: https://fstec.ru (дата обращения: 15.09.2026).

29. ГОСТ Р ИСО/МЭК 27001–2021. Информационная технология. Методы и средства обеспечения безопасности. Системы менеджмента информационной безопасности. Требования. Москва : Российский институт стандартизации, 2021. 30 с.

30. ГОСТ Р ИСО/МЭК 27005–2010. Информационная технология. Методы и средства обеспечения безопасности. Менеджмент риска информационной безопасности. Москва : Стандартинформ, 2011. 51 с.

31. ГОСТ Р 56546–2015. Защита информации. Уязвимости информационных систем. Классификация уязвимостей информационных систем. Москва : Стандартинформ, 2015. 12 с.

32. Chandramouli R., Kautz F., Torres-Arias S. Strategies for the Integration of Software Supply Chain Security in DevSecOps CI/CD Pipelines : NIST Special Publication 800-204D. Gaithersburg : NIST, 2024. 44 p.

33. Common Weakness Enumeration (CWE) / The MITRE Corporation. 2025. URL: https://cwe.mitre.org (дата обращения: 15.09.2026).

34. Common Attack Pattern Enumeration and Classification (CAPEC) / The MITRE Corporation. 2025. URL: https://capec.mitre.org (дата обращения: 15.09.2026).

35. ENISA Threat Landscape for Supply Chain Attacks / European Union Agency for Cybersecurity (ENISA). 2023. URL: https://www.enisa.europa.eu (дата обращения: 15.09.2026).

ПРИЛОЖЕНИЕ А

База знаний «этап конвейера — недостаток — техника — ущерб»

Таблица А.1 – База знаний недостатков безопасности CI/CD-процессов

Этап конвейера	Недостаток (OWASP)	Техника (ATT&CK)	Наступающий ущерб
Репозиторий кода	Отсутствие защиты веток (CICD-SEC-1)	T1195.002	Обход контроля потока изменений
Репозиторий кода	Ненадлежащее управление доступом (CICD-SEC-2)	T1078	Несанкционированное изменение кода и конвейера
Репозиторий кода	Секрет в истории репозитория (CICD-SEC-6)	T1552.001	Раскрытие учётных данных конвейера
Подключение зависимостей	Dependency confusion (CICD-SEC-3)	T1195.001	Внедрение вредоносного кода в сборку
Подключение зависимостей	Недоверенный источник пакетов (CICD-SEC-3)	T1195.002	Компрометация цепочки поставки
Система сборки	Исполнение недоверенного кода — PPE (CICD-SEC-4)	T1059	Исполнение произвольного кода в исполнителе
Система сборки	Избыточные права исполнителя (CICD-SEC-5)	T1078	Повышение полномочий, боковое перемещение
Система сборки	Небезопасная конфигурация (CICD-SEC-7)	T1610	Выход за пределы среды исполнения
Хранилище секретов	Долгоживущий токен (CICD-SEC-6)	T1552.001	Доступ в промышленную среду
Хранилище секретов	Приватный ключ в конфигурации (CICD-SEC-6)	T1552.004	Подмена доверенных артефактов
Хранилище артефактов	Отсутствие проверки подписи (CICD-SEC-9)	T1574	Развёртывание подменённого артефакта
Хранилище артефактов	Компрометация двоичного файла (CICD-SEC-9)	T1554	Внедрение закладки в поставляемый продукт
Внешние сервисы	Избыточные права интеграции (CICD-SEC-8)	T1199	Доступ к конвейеру через доверенные связи
Среда развёртывания	Избыточные права доставки (CICD-SEC-5)	T1078	Прямой доступ в промышленную среду
Наблюдаемость	Недостаточное журналирование (CICD-SEC-10)	T1562	Сокрытие следов, затруднение расследования

ПРИЛОЖЕНИЕ Б

Реестр секретов конвейера, ранжированный по области действия

Таблица Б.1 – Реестр секретов конвейера

Секрет	Область действия	Срок жизни	Достижимые среды	Уровень ущерба
Токен реестра артефактов	Публикация образов	Постоянный	Реестр, среда развёртывания	Критический
Токен развёртывания	Доступ к промышленной среде	Постоянный	Промышленная среда	Критический
Ключ доступа к репозиторию	Чтение и запись кода	90 суток	Репозиторий	Высокий
Токен внешнего сервиса	Интеграция с внешним API	Постоянный	Внешний сервис	Средний